

Aula 9 - Gestão de riscos em TI

Ameaça, vulnerabilidade, impacto, probabilidade, controle, tratamento e risco residual

Material original elaborado para revisão objetiva no padrão FGV. Recorte aderente ao edital vigente: Segurança da Informação e Governança de TI - gestão de riscos em tecnologia da informação. O foco é reconhecer conceitos próximos em cenários de sistemas, APIs, ambiente corporativo e setor público.

Referências técnicas de apoio: edital retificado TJSC 2026; Manual Mestre de Calibração FGV do projeto; provas oficiais FGV correlatas; NIST SP 800-30 Rev. 1; NIST SP 800-37 Rev. 2; NIST SP 800-39; ISO 31000; ISO/IEC 27005; referências de governança e segurança compatíveis com o edital.

1. Recorte da aula e objetivo de prova

Esta é a Aula 9 da trilha de Segurança da Informação e Governança de TI. Ela cobre o item de edital relacionado à gestão de riscos em tecnologia da informação, com foco nos conceitos que a FGV costuma transformar em alternativas próximas: ameaça, vulnerabilidade, impacto, probabilidade, controle, tratamento e risco residual.

O objetivo não é transformar a aula em um tratado de ISO, NIST ou auditoria. O objetivo é permitir que você resolva questões em que a banca descreve uma situação concreta - por exemplo, uma API exposta, um vazamento de credenciais, uma falha de segregação de funções, um risco aceito pela gestão ou uma matriz de risco - e pergunta qual conceito foi aplicado corretamente.

O que esta aula cobre

- conceitos de risco em TI e segurança da informação;
- diferença entre risco, ameaça, vulnerabilidade, impacto, probabilidade, incidente e controle;
- risco inerente, risco residual, apetite ao risco e tolerância ao risco;
- controles preventivos, detectivos e corretivos; controles administrativos, técnicos e físicos;
- processo de gestão de riscos: contexto, identificação, análise, avaliação, tratamento, comunicação, monitoramento e revisão;
- opções de tratamento de risco: evitar, reduzir/mitigar, compartilhar/transferir e aceitar;
- matriz de risco, registro de riscos e exemplos com APIs, Keycloak, pipelines, bancos de dados e sistemas públicos.

O que não deve dominar esta aula

Criptografia, PKI, OWASP, SAML, LGPD, COBIT e ITIL podem aparecer como apoio, mas não são o núcleo aqui. A pergunta principal desta aula é: diante de uma situação de TI, qual é o risco, de onde ele nasce, como é estimado, que controle o modifica e que risco permanece após o tratamento?

2. Modelo mental: risco não é sinônimo de problema

Em segurança e governança de TI, risco é uma possibilidade de perda, dano, interrupção ou efeito indesejado sobre objetivos organizacionais. Em um sistema público, esses objetivos podem envolver continuidade do serviço jurisdicional, sigilo processual, integridade de documentos, proteção de dados pessoais, rastreabilidade e conformidade normativa.

A FGV tende a explorar confusões. O candidato lê 'houve vazamento' e marca risco; mas, se o evento já ocorreu, normalmente estamos diante de um incidente. O risco existia antes: por exemplo, credenciais administrativas armazenadas sem proteção adequada poderiam permitir acesso indevido. A vulnerabilidade era a má gestão de secrets; a ameaça poderia ser um atacante, um insider ou um malware; o impacto poderia ser vazamento de dados, sanção, indisponibilidade ou dano reputacional.

Frase-chave para prova: risco é cenário possível; incidente é materialização de um evento adverso; vulnerabilidade é fraqueza explorável; ameaça é causa potencial; controle é medida que altera probabilidade ou impacto; risco residual é o que resta após controles e tratamento.

Conceitos essenciais

Termo	Ideia central	Exemplo em TI
Ativo	Algo que tem valor para a organização e precisa ser protegido.	Base de dados processual, API interna, credencial de serviço, pipeline CI/CD, logs de auditoria.
Ameaça	Causa potencial de um incidente ou evento indesejado.	Atacante externo, usuário interno mal-intencionado, erro humano, ransomware, falha elétrica.

Termo	Ideia central	Exemplo em TI
Vulnerabilidade	Fraqueza que pode ser explorada por uma ameaça.	Token sem expiração adequada, senha padrão, endpoint sem autorização, bucket público, dependência vulnerável.
Impacto	Consequência caso o evento ocorra.	Indisponibilidade do sistema, vazamento de dados, alteração indevida, sanção, perda de confiança.
Probabilidade	Chance de o evento ocorrer, considerando ameaças, vulnerabilidades e controles existentes.	Maior quando há exposição pública, histórico de exploração e controle fraco.
Risco	Combinação entre possibilidade de ocorrência e consequência para objetivos.	API sem rate limiting e sem bloqueio pode sofrer abuso, gerando indisponibilidade e fraude.
Controle	Medida que modifica o risco, reduzindo probabilidade, impacto ou aumentando capacidade de detecção/resposta.	MFA, revisão de permissões, WAF, backup testado, segregação de funções, monitoramento.
Risco residual	Risco remanescente após tratamento e controles.	Mesmo com MFA e logs, ainda existe risco de phishing sofisticado ou abuso por usuário legítimo.

3. Ameaça, vulnerabilidade, impacto e probabilidade

A forma mais eficiente de pensar risco em TI é montar um cenário. Um cenário de risco combina: ativo afetado, ameaça, vulnerabilidade explorável, evento possível, probabilidade e impacto. Sem essa montagem, o candidato costuma misturar conceitos.

Ameaça

Ameaça é a fonte ou circunstância capaz de explorar uma vulnerabilidade e causar dano. Pode ser intencional ou acidental; humana, técnica, ambiental ou organizacional. Em prova, a ameaça muitas vezes aparece como 'atacante', 'usuário interno', 'falha de energia', 'ransomware', 'erro operacional' ou 'indisponibilidade de fornecedor'.

Vulnerabilidade

Vulnerabilidade é a fraqueza. Ela não é o dano e não é necessariamente o agente causador. Uma API sem validação de autorização por recurso possui vulnerabilidade. O atacante que tenta explorar essa falha é ameaça. O vazamento de dados é impacto ou incidente, conforme o contexto do enunciado.

Probabilidade

Probabilidade, também chamada de likelihood em materiais técnicos, é a chance de ocorrência do cenário. Ela aumenta quando a vulnerabilidade é explorável, o ativo é exposto, há histórico de ataques, o controle é frágil ou a ameaça tem capacidade e motivação. Em avaliação qualitativa, costuma ser classificada como baixa, média ou alta. Em avaliação quantitativa, pode usar frequência esperada, perdas esperadas ou valores monetários, mas isso raramente é o centro da FGV em prova de Analista de Sistemas.

Impacto

Impacto é o efeito sobre objetivos organizacionais se o evento ocorrer. Para o TJSC, pense em indisponibilidade de sistemas judiciais, violação de sigilo, perda de integridade de documentos, dano à prestação jurisdicional, exposição de dados pessoais, descumprimento normativo e dano reputacional.

Situação	Conceito mais provável
Endpoint público permite consultar dados sem checar se o usuário tem permissão sobre aquele processo.	Vulnerabilidade de autorização; risco de acesso indevido; possível impacto em confidencialidade e LGPD.
Grupo criminoso tenta explorar credenciais vazadas de servidores públicos.	Ameaça, com evento de autenticação indevida se houver sucesso.
Sistema processual fica fora do ar durante expediente por falha de infraestrutura.	Incidente; impacto em disponibilidade; risco já se materializou.
A administração decide manter temporariamente um sistema legado aceitando formalmente o risco de baixa severidade.	Aceitação de risco; risco residual documentado.
Após implantação de MFA, ainda existe chance de sessão roubada por malware no endpoint.	Risco residual, pois controles reduziram, mas não eliminaram totalmente o risco.

4. Risco inerente, controle e risco residual

Risco inerente é o nível de risco existente antes da aplicação ou consideração dos controles. Risco residual é o risco que permanece depois dos controles existentes ou após o tratamento definido. A FGV costuma explorar alternativas que dizem que controle elimina risco. Em segurança real, controle reduz, detecta, transfere ou limita risco; eliminação total é exceção e, na prática, raramente defensável.

Fórmula mental

Risco inerente -> aplicar controles/tratamento -> risco residual. Se o residual estiver acima do apetite ou tolerância ao risco, é preciso novo tratamento, aceitação formal em nível competente ou descontinuação/evitação da atividade.

Controle

Controle é qualquer medida administrativa, técnica, física ou organizacional que modifica risco. Ele pode diminuir a probabilidade de ocorrência, reduzir o impacto, permitir detecção rápida, melhorar resposta ou preservar evidências. Em ambiente bancário ou público, controles fortes incluem segregação de funções, trilha de auditoria, revisão periódica de acessos, autenticação multifator, gestão de mudanças, backup testado e monitoramento centralizado.

Classificação	O que significa	Exemplos
Preventivo	Busca impedir ou reduzir a chance de ocorrência antes do evento.	MFA, menor privilégio, validação de autorização, hardening, treinamento contra phishing.
Detectivo	Identifica ocorrência, tentativa ou indício de evento.	Logs, SIEM, alertas de anomalia, DAST, monitoramento de falhas de login.
Corretivo	Atua após evento para restaurar, corrigir ou reduzir dano.	Plano de resposta, restauração de backup, revogação de tokens, patch emergencial.
Administrativo	Política, processo, regra, governança ou procedimento.	Política de acesso, matriz RACI, norma de classificação da informação.
Técnico/lógico	Controle implementado em sistema, rede ou aplicação.	Criptografia, ACL, WAF, validação de escopo, RBAC/ABAC, secrets vault.
Físico	Proteção do ambiente físico ou equipamento.	Controle de acesso a datacenter, CFTV, nobreak, sala segura.

Apetite e tolerância ao risco

Apetite ao risco é o nível de risco que a organização está disposta a aceitar para perseguir seus objetivos. Tolerância ao risco é a variação aceitável em relação a esse nível, normalmente mais operacional. Em prova, se o risco residual está acima do apetite/tolerância, não basta dizer 'monitorar'. A organização deve tratar, escalar ou aceitar formalmente no nível competente, conforme governança definida.

5. Processo de gestão de riscos em TI

Em termos práticos, gestão de riscos não é uma planilha estática. É um processo contínuo de identificar, analisar, avaliar, tratar, comunicar e monitorar riscos. Normas e guias usam nomes diferentes, mas a lógica geral se repete. A FGV pode cobrar esse fluxo com palavras próximas.

Etapa	Pergunta que ela responde	Exemplo
Estabelecer contexto	Qual é o escopo, critério e objetivo da análise?	Avaliar riscos de uma API de consulta processual exposta ao portal.
Identificar riscos	O que pode dar errado e quais ativos podem ser afetados?	Credencial vazada, endpoint sem autorização, indisponibilidade de provedor.
Analisar riscos	Qual a probabilidade e o impacto? Quais controles já existem?	Probabilidade alta por endpoint público; impacto alto por dados sensíveis.
Avaliar riscos	O nível calculado é aceitável? Qual prioridade?	Risco crítico deve ser tratado antes do go-live.
Tratar riscos	Qual resposta será adotada?	Implementar RBAC/ABAC, MFA, rate limiting e logs; ou adiar implantação.
Comunicar e consultar	Quem precisa participar e conhecer a decisão?	Dono do sistema, segurança, DPO/encarregado, jurídico, negócio, operação.
Monitorar e revisar	O risco mudou? O controle continua eficaz?	Revisão após incidente, mudança de arquitetura, nova vulnerabilidade ou novo requisito.

Matriz de risco

A matriz de risco cruza probabilidade e impacto para priorizar ações. Ela não é uma verdade matemática absoluta; é uma ferramenta de decisão. A banca pode tentar induzir que risco baixo nunca precisa ser monitorado ou que risco alto sempre deve ser eliminado. Cuidado: risco baixo pode ser aceito e monitorado; risco alto deve receber tratamento ou aceite formal, mas nem sempre será eliminado.

Probabilidade / Impacto	Baixo	Médio	Alto
Baixa	Baixo	Baixo/Médio	Médio
Média	Baixo/Médio	Médio	Alto
Alta	Médio	Alto	Crítico

Registro de riscos

O registro de riscos é um artefato de gestão: documenta riscos identificados, causas, impactos, probabilidade, controles, tratamento, responsável, prazo, status e risco residual. A FGV pode descrevê-lo como inventário vivo, não como documento meramente burocrático.

Campo	O que registra
Descrição do risco	Cenário de risco em linguagem compreensível.

Campo	O que registra
Ativo/processo afetado	Sistema, API, dado, serviço ou processo que sofre o efeito.
Causa ou ameaça	O que pode provocar o evento.
Vulnerabilidade	Fraqueza que permite ou facilita o evento.
Impacto e probabilidade	Critérios para priorização.
Controles existentes	Medidas já implementadas.
Resposta/tratamento	Evitar, reduzir, transferir/compartilhar ou aceitar.
Risco residual	Nível remanescente após o tratamento.
Responsável e prazo	Accountability pela ação e acompanhamento.

6. Tratamento de riscos

Tratamento de risco é a escolha e implementação de uma resposta. A palavra tratamento não significa sempre mitigação. A organização pode evitar, reduzir, compartilhar/transferir ou aceitar o risco, conforme critérios, custo-benefício, apetite, obrigação legal e criticidade do serviço.

Opção	Sentido	Exemplo em TI
Evitar	Eliminar a atividade que gera o risco ou mudar a abordagem para não se expor a ele.	Cancelar a exposição pública de uma API enquanto não houver autorização por recurso.
Reduzir/mitigar	Implementar controles para reduzir probabilidade ou impacto.	Implantar MFA, validação de escopo, WAF, rate limiting, backup e segregação de funções.
Compartilhar/transferir	Passar parte do impacto a terceiro, sem eliminar responsabilidade.	Seguro cibernético, cláusulas contratuais, provedor gerenciado. Atenção: responsabilidade pública e LGPD não desaparecem.
Aceitar	Assumir formalmente o risco residual dentro do apetite/tolerância ou por decisão competente.	Manter risco baixo documentado até próxima janela de manutenção.

Custo-benefício e proporcionalidade

Controle deve ser proporcional ao risco. Não faz sentido gastar mais com o controle do que o impacto provável, salvo quando há obrigação legal, risco à vida, risco institucional grave ou exigência de conformidade. Em prova, uma alternativa dizendo que todo risco alto deve ser eliminado a qualquer custo tende a estar errada. A decisão deve considerar objetivo, criticidade, custo, eficácia, restrição legal e apetite ao risco.

7. Risco em APIs, Keycloak, esteiras e sistemas corporativos

Como você trabalha com APIs, autenticação, esteiras e sistemas internos, traduza os conceitos para cenários concretos. Essa associação aumenta a chance de acertar questões situacionais da FGV.

API com autenticação, mas sem autorização fina

Imagine uma API em Quarkus que valida token emitido pelo Keycloak, mas não verifica se o usuário pode acessar o recurso solicitado. O sistema autentica corretamente, mas falha na autorização. A vulnerabilidade é ausência de controle de acesso por objeto/recurso; a ameaça é o uso indevido por usuário autenticado; o impacto é exposição de dados; controles possíveis incluem RBAC, ABAC, checagem por escopo, validação de ownership e logs de auditoria.

Pipeline com secret em variável exposta

Um token de deploy armazenado em variável de CI/CD sem proteção adequada aumenta a probabilidade de uso indevido por quem tem acesso à esteira ou ao log. O risco não é o token em si, mas o cenário: credencial exposta pode permitir alteração não autorizada em ambiente. Controles: secrets vault, mascaramento de logs, rotação, menor privilégio, aprovação de deploy, segregação de funções e monitoramento.

Sistema legado com risco aceito

Um sistema legado pode não suportar MFA ou segregação adequada. A gestão pode aceitar temporariamente o risco residual, mas isso exige justificativa, prazo, responsável e plano de acompanhamento. Em prova, 'aceitar risco' não é ignorar risco; é decisão formal e consciente.

8. Pegadinhas FGV

A FGV frequentemente cobra distinções por meio de alternativas que são tecnicamente verdadeiras, mas respondem a outro conceito. O segredo é identificar o núcleo do comando.

Pegadinha	Como aparece	Resposta segura
Risco x incidente	O enunciado descreve algo que já aconteceu e chama de risco.	Se ocorreu, é incidente/evento; risco era a possibilidade anterior.
Ameaça x vulnerabilidade	Atacante, malware ou erro humano são tratados como fraqueza do sistema.	A ameaça explora; a vulnerabilidade é explorada.
Impacto x probabilidade	Consequência é confundida com chance de ocorrência.	Impacto é dano; probabilidade é chance.
Controle elimina risco	A alternativa promete risco zero após controle.	Controle reduz, detecta, corrige ou transfere; residual normalmente permanece.
Aceitação informal	Gestor 'deixa para depois' sem registro.	Aceitar risco exige decisão formal dentro de critério e autoridade.
Transferência total	Seguro ou contrato eliminaria responsabilidade.	Compartilhamento/transferência não elimina accountability da organização.
Matriz como fórmula absoluta	Resultado da matriz é tratado como verdade objetiva imutável.	É instrumento de priorização; depende de critérios e revisão.

9. Métodos e critérios de avaliação de risco

A FGV pode cobrar a diferença entre análise qualitativa, semiquantitativa e quantitativa. A análise qualitativa usa categorias como baixo, médio, alto ou crítico. A semiquantitativa atribui pontuações, como probabilidade 1 a 5 e impacto 1 a 5. A quantitativa busca estimar perdas em valores mensuráveis, como custo esperado, frequência anualizada ou perda monetária. Em concursos de TI, normalmente a cobrança é conceitual: reconhecer o método e não confundir pontuação qualitativa com cálculo financeiro preciso.

Tipo de análise	Como funciona	Pegadinha de prova
Qualitativa	Classifica probabilidade e impacto por categorias, como baixo, médio e alto.	Não gera valor monetário exato; serve para priorizar e orientar decisão.
Semiquantitativa	Usa escalas numéricas, por exemplo 1 a 5, para ordenar riscos.	Número não significa precisão matemática absoluta; depende dos critérios definidos.
Quantitativa	Tenta medir perdas e frequências em termos financeiros ou estatísticos.	Exige dados confiáveis; não é sempre viável para todos os riscos de TI.

Critérios de impacto

Impacto pode ser avaliado em várias dimensões. Em órgão público, a dimensão financeira é apenas uma delas. A FGV pode usar alternativas que limitam risco a custo financeiro, mas risco de TI também envolve indisponibilidade do serviço público, violação de sigilo, perda de integridade, descumprimento legal, dano reputacional e prejuízo à confiança social.

Dimensão de impacto	Exemplo no TJSC ou ambiente público
Operacional	Sistema indisponível impede atendimento, distribuição, consulta ou prática de atos.
Legal/regulatório	Tratamento inadequado de dados pessoais ou descumprimento de política institucional.
Confidencialidade	Exposição indevida de processos sigilosos, dados pessoais ou credenciais.
Integridade	Alteração indevida de documentos, registros ou parâmetros de autorização.
Imagem/reputação	Perda de confiança no serviço digital do órgão.
Financeiro	Custo de resposta, contratação emergencial, multa, recomposição ou retrabalho.

Critérios de probabilidade

Probabilidade não é chute livre. Ela deve considerar exposição, histórico, capacidade e motivação da ameaça, explorabilidade da vulnerabilidade, atratividade do ativo e efetividade dos controles existentes. Em uma API pública com vulnerabilidade conhecida e sem monitoramento, a probabilidade tende a ser maior do que em serviço interno segmentado, com autenticação forte, logs e poucos usuários.

10. Papéis: proprietário do risco, dono do ativo e responsável pelo controle

Em governança, risco precisa de dono. Se ninguém responde pelo risco, o registro vira inventário sem ação. O proprietário do risco é quem tem autoridade ou responsabilidade pela decisão de tratamento, aceite e priorização. O dono do ativo conhece valor, criticidade e uso do ativo. O responsável pelo controle implementa ou opera a medida definida. Em organizações públicas e bancárias, esses papéis podem estar distribuídos entre área de negócio, TI, segurança, privacidade, infraestrutura, desenvolvimento e gestão contratual.

Papel	Responsabilidade típica	Erro comum
Proprietário do risco	Decidir ou escalar tratamento, aceitar residual conforme autoridade e acompanhar status.	Achar que risco de TI é sempre responsabilidade exclusiva do desenvolvedor.
Dono do ativo	Informar criticidade, requisitos de sigilo, disponibilidade e integridade do ativo.	Tratar todos os ativos como se tivessem igual valor e exposição.
Responsável pelo controle	Implementar, operar, testar ou evidenciar o controle.	Confundir operação do controle com aceite do risco.
Segurança/GRC	Metodologia, critérios, monitoramento, apoio técnico e reporte.	Tomar decisão de risco de negócio sem autoridade ou contexto.
Alta gestão/comitê	Definir apetite, prioridades e decisões relevantes de exposição institucional.	Delegar riscos críticos sem critério formal.

Risco de terceiros e cadeia de suprimentos

Risco de terceiros ocorre quando fornecedor, prestador, biblioteca, API externa ou provedor de nuvem afeta os objetivos da organização. O tratamento pode envolver cláusulas contratuais, SLA, due diligence, avaliação de segurança, plano de contingência, criptografia, segregação e monitoramento. A

pegadinha é afirmar que terceirização transfere integralmente o risco. Ela pode compartilhar impacto e responsabilidade operacional, mas não elimina accountability do órgão contratante perante cidadãos, usuários e normas aplicáveis.

11. Exemplo completo: registro de risco de uma API

Cenário: uma API de consulta de documentos internos será exposta a um portal. Ela usa autenticação federada, mas a autorização por recurso ainda está incompleta. O sistema manipula dados pessoais e documentos administrativos com diferentes níveis de sensibilidade.

Campo	Exemplo preenchido
Risco	Usuário autenticado acessar documento de terceiro por ausência de checagem de autorização por objeto.
Ativo	API de documentos, base de dados documental e trilhas de auditoria.
Ameaça	Usuário autenticado curioso ou mal-intencionado; automação explorando IDs sequenciais.
Vulnerabilidade	Controle de autorização insuficiente no backend; dependência excessiva da autenticação.
Impacto	Violação de confidencialidade, exposição de dados pessoais, dano institucional e possível descumprimento normativo.
Probabilidade	Média/alta se endpoint for público, IDs forem previsíveis e não houver monitoramento.
Controles existentes	Autenticação via provedor de identidade, TLS, logs básicos e perfis gerais.
Tratamento	Implementar autorização por recurso, escopos adequados, validação de ownership, testes negativos, logs auditáveis e alertas.
Risco residual	Baixo/médio, condicionado a teste, revisão de acesso e monitoramento contínuo.
Responsável	Dono do sistema com apoio de desenvolvimento, segurança e privacidade.

Esse exemplo é típico de prova porque permite cobrar autenticação x autorização, ameaça x vulnerabilidade, impacto x probabilidade, controle preventivo, controle detectivo e risco residual em um único cenário. A FGV gosta desse tipo de item porque separa o candidato que decorou termos daquele que entende o fluxo de risco.

12. Integração com SGSI, COBIT e ITIL sem sair do edital

Gestão de riscos em TI conversa com outros tópicos da disciplina. Em um Sistema de Gestão de Segurança da Informação (SGSI), riscos orientam controles, políticas e planos de tratamento. No COBIT 2019, gestão de riscos aparece ligada à governança e ao alinhamento entre informação, tecnologia e objetivos organizacionais. Na ITIL 4, riscos aparecem dentro da gestão de serviços, continuidade, mudanças, incidentes e nível de serviço. Para esta aula, entretanto, o ponto de prova é o conceito operacional de risco: identificar, analisar, avaliar, tratar e monitorar.

A banca pode construir uma alternativa verdadeira sobre COBIT ou ITIL, mas que não responda ao comando da questão. Por exemplo: se o enunciado pede a diferença entre risco residual e risco inerente, uma alternativa falando de cadeia de valor de serviço pode ser correta em abstrato, mas errada no contexto. Esse é um padrão clássico de distrator técnico próximo.

13. Checklist final da aula

- Se o evento já ocorreu, pense em incidente; se ainda é possibilidade, pense em risco.
- Ameaça é causa potencial; vulnerabilidade é fraqueza; impacto é consequência; probabilidade é chance.
- Risco inerente vem antes dos controles; risco residual vem depois dos controles/tratamento.

- Controle preventivo reduz chance; detectivo identifica; corretivo restaura/corrige.
- Tratamento de risco não é sempre mitigação: pode evitar, reduzir, compartilhar/transferir ou aceitar.
- Aceitar risco exige decisão formal, critério e autoridade; não é negligenciar.
- Terceirização, seguro e contrato podem compartilhar impacto, mas não fazem a organização perder responsabilidade pelo risco.
- Matriz de risco ajuda a priorizar; não substitui julgamento, contexto e revisão.

14. Questões autorais - padrão FGV

As questões a seguir não reproduzem itens reais. Elas foram elaboradas para simular vocabulário, densidade e tipos de cobrança compatíveis com a FGV em TI, segurança e governança.

1. Em um órgão público, uma API de consulta processual exige autenticação via provedor de identidade, mas não verifica se o usuário autenticado possui vínculo com o processo solicitado. Após análise, a equipe de segurança classifica o cenário como risco relevante à confidencialidade. Nessa situação, a fraqueza que torna possível o acesso indevido é melhor descrita como:

- (A) ameaça, pois o usuário autenticado é o agente que causa o dano.
- (B) impacto, pois a exposição de dados pessoais decorre da falha de autorização.
- (C) risco residual, pois a autenticação já foi implementada e todo risco restante é residual.
- (D) vulnerabilidade, pois há deficiência no controle de autorização por recurso.
- (E) apetite ao risco, pois a organização optou por expor a API ao público.

2. Uma equipe avaliou que determinada falha em pipeline de integração contínua poderia permitir a leitura de secrets de deploy por usuários sem necessidade operacional. Antes de implantar controles adicionais, estimou o nível de risco do cenário. A avaliação realizada nesse momento se refere, em regra, ao risco:

- (A) residual, pois qualquer risco em ambiente de produção já considera controles implementados.
- (B) inerente, pois ainda se estima o risco antes do tratamento específico definido para o cenário.
- (C) aceito, pois a equipe já conhece a falha e decidiu documentá-la.
- (D) transferido, pois o pipeline normalmente depende de ferramenta de terceiro.
- (E) operacional inexistente, pois secrets de deploy são apenas ativos técnicos, não riscos de negócio.

3. Considere as afirmativas sobre gestão de riscos em tecnologia da informação. I. Ameaças podem ser intencionais ou acidentais. II. Vulnerabilidade é a consequência negativa materializada sobre o objetivo organizacional. III. Probabilidade e impacto são critérios usuais para estimar nível de risco. Está correto o que se afirma em:

- (A) I, apenas.
- (B) II, apenas.
- (C) I e II, apenas.
- (D) II e III, apenas.
- (E) I e III, apenas.

4. Um Tribunal mantém sistema legado que não permite autenticação multifator. Após análise formal, a autoridade competente decide manter o sistema por 90 dias, com restrição de acesso por rede, monitoramento intensificado, plano de substituição e registro da decisão. O tratamento aplicado ao risco remanescente é melhor caracterizado como:

- (A) aceitação formal de risco residual, acompanhada de controles compensatórios e prazo.
- (B) eliminação do risco, já que o acesso por rede restrita impede exploração externa.
- (C) transferência integral do risco para a equipe de infraestrutura responsável pela rede.
- (D) mera identificação de vulnerabilidade, pois não há resposta de tratamento descrita.
- (E) recuperação de desastre, pois o sistema legado permanece em produção.

5. No contexto de controles de segurança, relacione os itens a seguir. 1. Preventivo. 2. Detectivo. 3. Corretivo. () Alerta de SIEM para autenticações incomuns. () MFA antes de acesso administrativo. () Restauração de backup após corrupção de dados. A sequência correta é:

- (A) 1 - 2 - 3.
- (B) 2 - 3 - 1.
- (C) 2 - 1 - 3.
- (D) 3 - 2 - 1.
- (E) 1 - 3 - 2.

6. Em uma reunião de governança, foi apresentado o seguinte cenário: 'um fornecedor externo de mensageria pode ficar indisponível, afetando notificações automáticas aos usuários'. A equipe contratual propôs cláusulas de nível de serviço e penalidades, mantendo plano alternativo interno para mensagens críticas. A resposta ao risco combina, predominantemente:

- (A) eliminação e aceitação, pois cláusula contratual elimina a indisponibilidade.
- (B) detecção e apetite ao risco, pois SLA é apenas indicador de monitoramento.
- (C) compartilhamento/transferência parcial e redução, pois parte do impacto é contratualmente alocada e há alternativa operacional.
- (D) risco inerente e ameaça, pois contrato não é forma de tratamento.
- (E) recuperação de desastre e incidente, pois a indisponibilidade já ocorreu.

7. Assinale a opção que melhor representa a diferença entre risco e vulnerabilidade em TI.

- (A) Risco é a possibilidade de efeito negativo sobre objetivos; vulnerabilidade é a fraqueza explorável que pode contribuir para esse risco.
- (B) Risco é sempre externo à organização; vulnerabilidade é sempre interna ao código da aplicação.
- (C) Risco é evento materializado; vulnerabilidade é o impacto financeiro decorrente do evento.
- (D) Risco e vulnerabilidade são sinônimos em segurança da informação, distinguindo-se apenas em normas de auditoria.
- (E) Risco é o controle implementado para reduzir a ameaça; vulnerabilidade é a ameaça residual.

8. Um gestor afirma que, após contratar seguro cibernético, o órgão não precisa mais manter controles de segurança sobre determinado sistema. À luz da gestão de riscos em TI, essa afirmação é:

- (A) correta, pois transferência de risco extingue obrigações técnicas e legais do contratante.
- (B) correta, desde que o prêmio do seguro seja inferior ao impacto máximo estimado.
- (C) incorreta, pois seguro cibernético é controle preventivo e não medida de tratamento.
- (D) correta apenas quando o risco envolver dados pessoais tratados por operador externo.
- (E) incorreta, pois transferência ou compartilhamento não elimina a responsabilidade de gerir o risco e manter controles proporcionais.

9. Uma matriz de risco de três níveis classifica como crítico o cenário em que a probabilidade é alta e o impacto é alto. A área técnica, no entanto, argumenta que os critérios usados não consideraram a exposição real do ativo nem os controles já existentes. Nesse caso, a crítica é pertinente porque a matriz:

- (A) deve sempre produzir resultado quantitativo monetário para ser válida.
- (B) dispensa critérios, pois basta cruzar qualquer probabilidade com qualquer impacto.
- (C) é substituto completo da análise técnica de vulnerabilidades.
- (D) é instrumento de priorização dependente de critérios, contexto e qualidade das informações utilizadas.
- (E) só pode ser aplicada a riscos financeiros, não a segurança da informação.

10. Em uma avaliação de risco, a equipe primeiro delimitou escopo, ativos críticos, critérios de impacto e responsabilidades; em seguida, identificou cenários e controles existentes. A atividade inicial descrita corresponde mais diretamente a:

- (A) tratamento de risco.
- (B) estabelecimento do contexto.
- (C) aceitação de risco residual.
- (D) comunicação de incidentes.
- (E) classificação de controles corretivos.

11. Considere as afirmativas: I. O risco residual deve ser analisado após a consideração dos controles existentes ou planejados. II. O risco inerente é aquele que permanece após a decisão formal de aceitação. III. A eficácia dos controles deve ser monitorada, pois mudanças no ambiente podem alterar o nível de risco. Está correto o que se afirma em:

- (A) I, apenas.

- (B) II, apenas.
- (C) I e III, apenas.
- (D) II e III, apenas.
- (E) I, II e III.

12. Um sistema interno registra logs de acesso, mas a organização não revisa os logs, não possui alertas e não definiu responsáveis por acompanhamento. Para fins de gestão de riscos, a simples existência dos logs é melhor interpretada como:

- (A) controle corretivo suficiente, pois permite restaurar o sistema após incidente.
- (B) transferência de risco, pois o log desloca a responsabilidade ao usuário registrado.
- (C) eliminação da ameaça, pois usuários sabem que são monitorados.
- (D) aceitação tácita, pois a organização decidiu não analisar os registros.
- (E) controle detectivo potencialmente incompleto, pois sua efetividade depende de monitoramento, análise e resposta.

13. Assinale a opção que apresenta, de forma mais adequada, um exemplo de risco residual.

- (A) Após implantação de MFA, revisão periódica de acessos e alerta de login anômalo, permanece a possibilidade de comprometimento por engenharia social sofisticada.
- (B) A existência de senha fraca em conta administrativa antes de qualquer correção.
- (C) O atacante externo que executa varredura contra portal público.
- (D) O vazamento de dados pessoais já confirmado após incidente.
- (E) A política de segurança que determina revisão semestral de perfis.

14. Um analista propõe desativar definitivamente uma funcionalidade pouco usada que expõe dados sensíveis e exigiria alto custo para adequação de segurança. Considerando as opções clássicas de tratamento, a proposta representa:

- (A) mitigação, pois a funcionalidade continua existindo com risco menor.
- (B) compartilhamento, pois o custo de segurança é deslocado aos usuários.
- (C) aceitação, pois o risco é mantido sem alteração.
- (D) evitação, pois a atividade que gera o risco é eliminada.
- (E) detecção, pois a desativação facilita auditoria posterior.

15. Na análise de risco de uma API, a equipe registrou: 'vazamento de dados pessoais sensíveis, sanção administrativa e perda de confiança institucional'. Esses elementos descrevem, principalmente:

- (A) probabilidades.
- (B) impactos.
- (C) ameaças.
- (D) controles preventivos.
- (E) vulnerabilidades técnicas.

16. Sobre comunicação e consulta no processo de gestão de riscos, assinale a opção correta.

- (A) Devem envolver partes interessadas relevantes, pois percepção de impacto, critérios de aceitação e decisão de tratamento não são exclusivamente técnicos.
- (B) Devem ocorrer somente depois do incidente, para não comprometer a confidencialidade da análise.
- (C) Devem ser restritas à equipe de desenvolvimento, pois risco de TI não envolve áreas de negócio.
- (D) Substituem a análise de probabilidade e impacto quando a organização possui matriz de risco.
- (E) São dispensáveis quando a ameaça é externa, pois o gestor não controla o atacante.

17. Em uma organização, um risco de indisponibilidade de serviço foi classificado como alto. A equipe implantou redundância, backup testado, monitoramento e procedimento de failover. Mesmo assim, verificou que uma falha regional simultânea ainda poderia causar indisponibilidade temporária. O conceito que melhor expressa essa possibilidade remanescente é:

- (A) risco inerente.
- (B) vulnerabilidade explorada.
- (C) ameaça eliminada.
- (D) impacto inexistente.
- (E) risco residual.

18. Considere a tabela abaixo. Cenário A: probabilidade alta, impacto baixo. Cenário B: probabilidade baixa, impacto alto. Cenário C: probabilidade alta, impacto alto. Sem outros critérios adicionais, o cenário que tende a receber maior prioridade de tratamento é:

- (A) A, porque eventos frequentes devem sempre prevalecer sobre impactos graves.
- (B) B, porque impacto alto sempre prevalece, ainda que a chance seja remota.
- (C) C, porque combina alta probabilidade e alto impacto, elevando o nível de risco.
- (D) A e B, pois ambos anulam o risco residual.
- (E) Nenhum, pois matriz qualitativa não pode apoiar priorização.

19. A equipe de segurança identificou que desenvolvedores podem aprovar suas próprias mudanças em produção. O principal risco associado a essa situação decorre da fragilidade de:

- (A) criptografia em repouso.
- (B) segregação de funções e controle de mudanças.
- (C) continuidade de serviços e RPO.
- (D) autenticação federada e SSO.
- (E) classificação de dados por confidencialidade.

20. Uma área decide aceitar um risco médio sem registrar justificativa, sem identificar responsável e sem submeter a decisão à autoridade prevista na política. Em uma visão adequada de governança de riscos, essa decisão é:

- (A) regular, pois riscos médios podem ser sempre aceitos pela área técnica.
- (B) regular, desde que o risco não envolva dados pessoais.
- (C) equivalente à transferência, pois a decisão foi tomada pela área de negócio.
- (D) inadequada, pois aceitação de risco exige registro, critério e autoridade competente.
- (E) obrigatória, pois tratar riscos médios viola proporcionalidade.

15. Gabarito resumido

1-D; 2-B; 3-E; 4-A; 5-C; 6-C; 7-A; 8-E; 9-D; 10-B; 11-C; 12-E; 13-A; 14-D; 15-B; 16-A; 17-E; 18-C; 19-B; 20-D.

16. Comentários completos

Questão 1 - Gabarito: D

A correta é D: a falha descrita é uma vulnerabilidade de autorização por recurso. A alternativa A confunde ameaça com vulnerabilidade: o usuário pode ser agente de exploração, mas a fraqueza é o controle ausente. B descreve impacto possível, não a fraqueza. C usa risco residual de forma automática; a autenticação não torna todo risco restante residual sem análise do tratamento. E confunde exposição ou decisão arquitetural com apetite ao risco.

Questão 2 - Gabarito: B

A correta é B: antes do tratamento específico, avalia-se risco inerente do cenário. A alternativa A erra porque risco residual vem após controles/tratamento considerados. C confunde conhecimento do risco com aceitação formal. D exagera a terceirização da ferramenta como transferência. E é falsa: secrets são ativos técnicos cujo comprometimento pode gerar risco operacional e institucional.

Questão 3 - Gabarito: E

A correta é E: I e III estão corretas. Ameaças podem ser intencionais ou acidentais; probabilidade e impacto são critérios usuais de análise. II está errada porque vulnerabilidade não é consequência negativa; é fraqueza explorável. A consequência é impacto ou dano.

Questão 4 - Gabarito: A

A correta é A: há aceitação formal de risco residual por prazo, com controles compensatórios. B erra ao prometer eliminação. C confunde responsabilidade de infraestrutura com transferência integral. D ignora que houve tratamento e decisão formal. E desloca o tema para recuperação de desastre, que não é o núcleo do caso.

Questão 5 - Gabarito: C

A correta é C: SIEM é detectivo; MFA é preventivo; restauração é corretiva. A, B, D e E trocam as funções dos controles. A pegadinha é achar que log ou alerta 'previne' por existir; sua função primária é detectar.

Questão 6 - Gabarito: C

A correta é C: cláusulas de SLA e penalidades compartilham/transferem parte do impacto contratual, enquanto plano alternativo reduz impacto operacional. A erra porque contrato não elimina indisponibilidade. B reduz SLA a indicador, sem reconhecer tratamento contratual. D diz que contrato não é tratamento, o que é falso. E pressupõe incidente já ocorrido.

Questão 7 - Gabarito: A

A correta é A. Risco é possibilidade de efeito sobre objetivos; vulnerabilidade é fraqueza explorável. B erra ao dizer que risco é sempre externo e vulnerabilidade sempre código. C troca risco por incidente e vulnerabilidade por impacto. D trata termos como sinônimos. E inverte controle, ameaça e vulnerabilidade.

Questão 8 - Gabarito: E

A correta é E: seguro ou contrato não eliminam a responsabilidade de gerir risco e manter controles. A e B atribuem ao seguro efeito absoluto. C erra porque seguro pode ser medida de compartilhamento/transferência, não controle preventivo típico. D erra ao limitar a hipótese a operador externo ou dados pessoais.

Questão 9 - Gabarito: D

A correta é D: matriz de risco é ferramenta de priorização dependente de critérios, contexto e informações. A erra porque matriz pode ser qualitativa. B banaliza critérios. C trata matriz como substituta de análise técnica. E restringe indevidamente a riscos financeiros.

Questão 10 - Gabarito: B

A correta é B: delimitar escopo, ativos, critérios e responsabilidades é estabelecer contexto. A trata resposta posterior. C é decisão sobre residual. D diz respeito a incidente. E classifica controles, mas não descreve a atividade inicial do processo.

Questão 11 - Gabarito: C

A correta é C: I e III estão corretas. Risco residual é analisado após controles; controles precisam ser monitorados. II está errada porque risco inerente é anterior ao tratamento/controles, não o que sobra após

aceitação.

Questão 12 - Gabarito: E

A correta é E: logs sem revisão e alerta são controle detectivo incompleto ou pouco efetivo. A confunde log com restauração. B erra ao deslocar responsabilidade ao usuário. C exagera efeito dissuasório. D pode parecer tentadora, mas ausência de análise não equivale automaticamente a aceitação formal de risco.

Questão 13 - Gabarito: A

A correta é A: controles foram implantados e ainda resta possibilidade de comprometimento; isso é risco residual. B é risco inerente ou vulnerabilidade antes do tratamento. C é ameaça. D é incidente/impacto materializado. E é controle administrativo.

Questão 14 - Gabarito: D

A correta é D: desativar a funcionalidade elimina a atividade que gerava o risco, caracterizando evitação. A daria respeito à redução mantendo a funcionalidade. B não envolve terceiro. C manteria o risco. E trata de detecção, que não é o caso.

Questão 15 - Gabarito: B

A correta é B: vazamento, sanção e perda de confiança são consequências, logo impactos. A é chance de ocorrência. C é causa potencial. D são medidas de proteção. E seriam fraquezas como endpoint sem autorização ou configuração inadequada.

Questão 16 - Gabarito: A

A correta é A: comunicação e consulta envolvem stakeholders relevantes porque risco de TI afeta negócio, jurídico, segurança, privacidade e operação. B restringe indevidamente ao pós-incidente. C reduz risco de TI à equipe técnica. D confunde comunicação com análise. E ignora que mesmo ameaças externas exigem decisão interna.

Questão 17 - Gabarito: E

A correta é E: após redundância, backup, monitoramento e failover, ainda existe risco remanescente. A seria o risco antes dos controles. B fala em vulnerabilidade já explorada, não descrita. C erra porque ameaça não foi eliminada. D ignora que ainda há impacto possível.

Questão 18 - Gabarito: C

A correta é C: alta probabilidade e alto impacto tendem a formar maior nível de risco. A e B exageram um único eixo. D afirma anulação do residual sem base. E erra porque matriz qualitativa pode apoiar priorização, embora não substitua julgamento.

Questão 19 - Gabarito: B

A correta é B: a pessoa que desenvolve e aprova sua própria mudança viola segregação de funções e enfraquece gestão de mudanças. A, C, D e E são temas relevantes em TI, mas não explicam o principal risco do cenário.

Questão 20 - Gabarito: D

A correta é D: aceitação de risco exige registro, critério e autoridade competente. A e B criam permissões gerais inexistentes. C confunde aceitação com transferência. E transforma proporcionalidade em obrigação de aceitar, o que é falso.

17. Referências utilizadas

Edital TJSC 2026 retificado - cargo Analista de Sistemas; Manual Mestre de Calibração FGV do projeto; cadernos oficiais FGV correlatos de Tecnologia da Informação, Governança de TI, Infraestrutura e Segurança; NIST SP 800-30 Rev. 1 - Guide for Conducting Risk Assessments; NIST SP 800-37 Rev. 2 - Risk Management Framework; NIST SP 800-39 - Managing Information Security Risk; ISO 31000:2018 - Risk management guidelines; ISO/IEC 27005:2022 - guidance on managing information security risks.